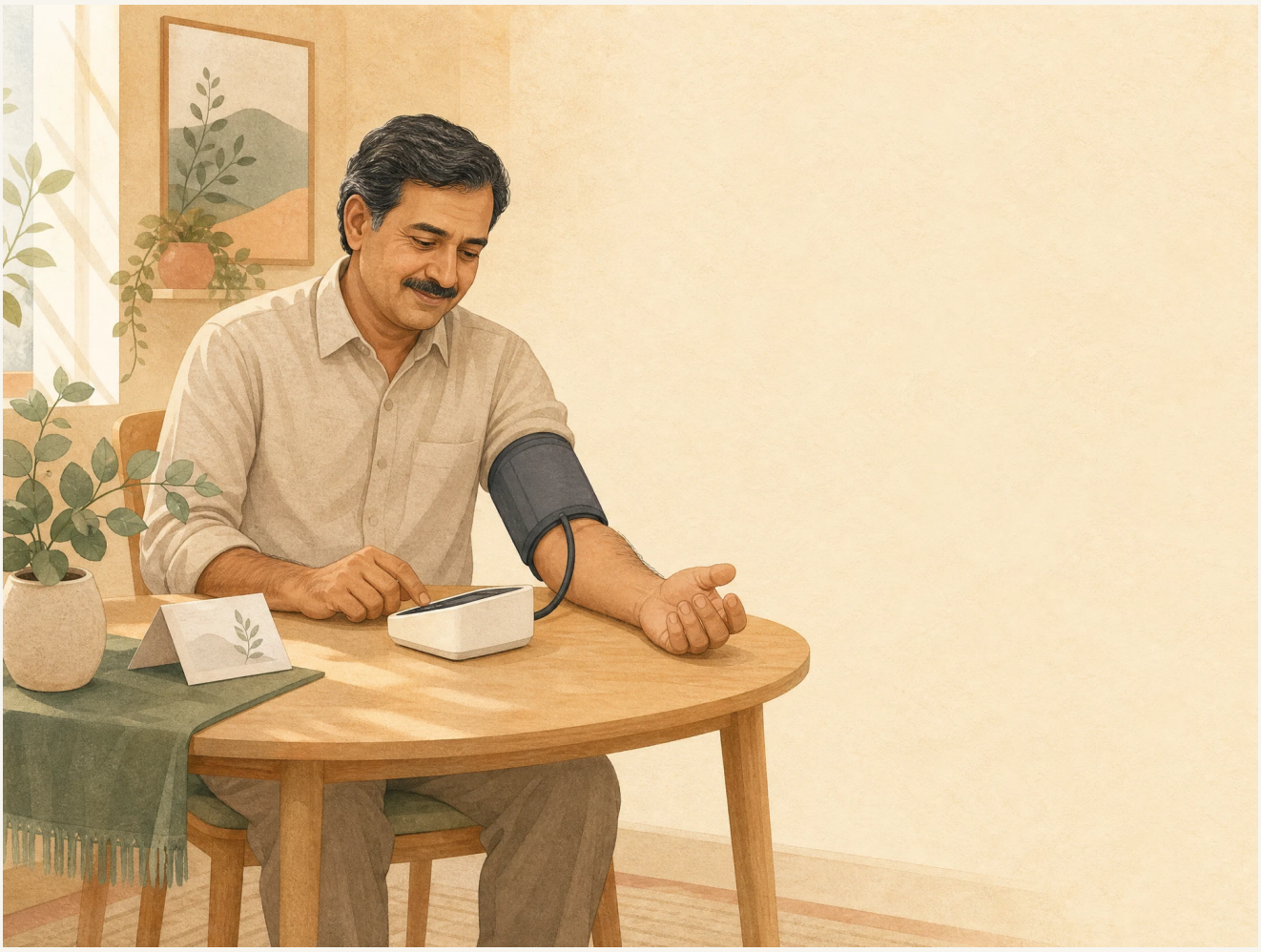
BP Passport

Technical brief

A bilingual, local-first blood-pressure care PWA for Pakistan



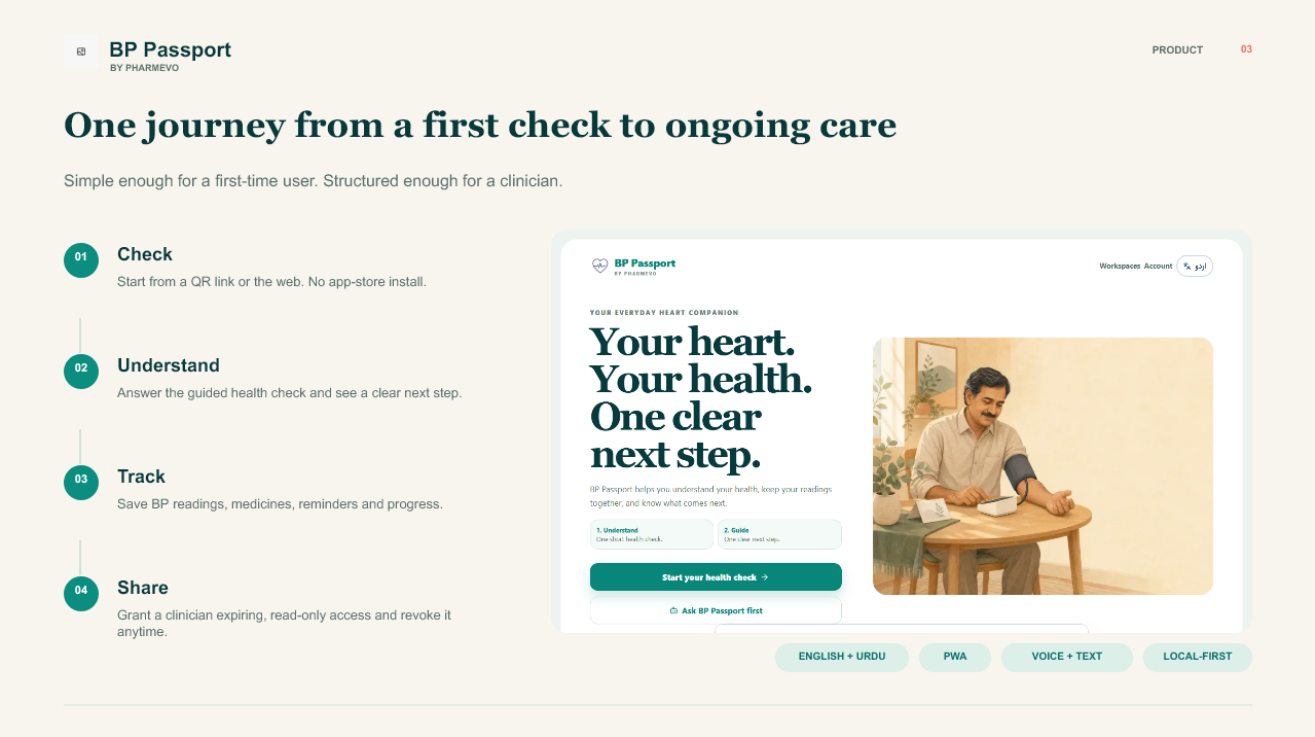
Purpose: help people check, understand and track blood pressure, then share structured records with a clinician under explicit consent.

Uzair Ahmad	Founder & CEO
Muhammad Suhaib	Co-Founder & Tech Lead
Location	Karachi, Sindh, Pakistan

October 2026

1. Product overview

BP Passport combines a guided health check, a longitudinal patient Passport and consent-controlled clinical review in one responsive web application.



EN + UR	3	16	12
true RTL	role-separated workspaces	API route handlers	ordered migrations

Current product surfaces

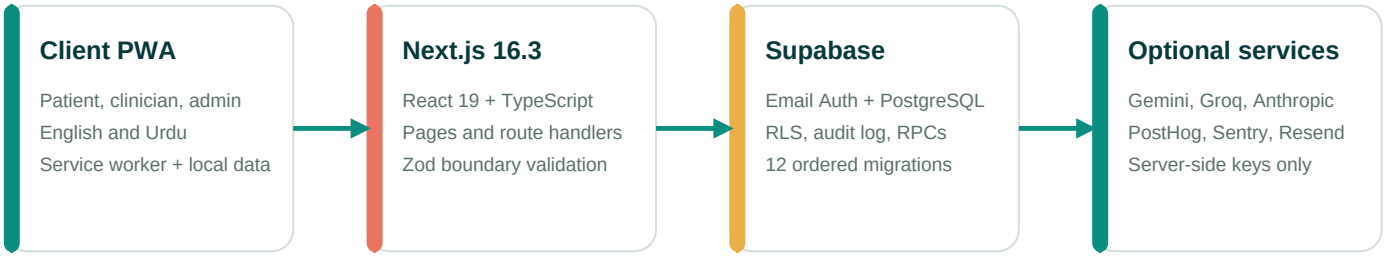
- Patient: health check, BP logging, medicines, reminders, reports, caregiver controls, streaks and a voice or text assistant.

- Clinician: separate portal, patient-authorized record access and structured BP history. Access is read-only, expiring and revocable.

- Programme: protected clinician review and pilot operations without placing admin tools inside the patient dashboard.

2. System architecture

The production code uses a compact full-stack architecture. The same Next.js repository serves UI routes and the API layer.



Local-first fallback

The health check and saved Passport work without cloud configuration.

Consented records sync when Supabase and the API environment are enabled.

Request and persistence model

Path	Behavior
Browser -> local storage	In-progress and saved care data can remain on-device. The basic flow works without backend configuration.
Browser -> Next.js API	Validated JSON or multipart requests. Cross-origin access is constrained when the API runs separately.
API -> Supabase	User bearer tokens preserve database RLS. Service-role access is limited to privileged admin and revocation workflows.
API -> model provider	Optional server-side call after deterministic triage. Provider failure falls back to the local coach.

Deployment options: one combined Next.js deployment, or Vercel for the web surface with the same repository running on Render for API routes.

3. Technology stack

Technology choices prioritize a small operational footprint, bilingual usability and strong database enforcement.

Layer	Current choice	Purpose
Web framework	Next.js 16.3 App Router, React 19.1	Patient PWA, clinician portal, admin console and route handlers in one codebase.
Language	TypeScript 5.7, strict mode	Typed UI, clinical rules, API boundaries and data adapters.
UI	Tailwind CSS v4, CSS-first tokens	Responsive design, full-screen desktop layouts and mobile breakpoints.
Localization	next-intl 4.13	English and Urdu route segments, true RTL and language switching throughout.
Validation	Zod 3.24	Request validation and bounded input at server routes.
Identity and data	Supabase Auth, PostgreSQL	Email authentication, user sessions, relational records, RPCs and RLS.
PWA	Manifest, service worker, offline page	Install prompt, cached shell and local fallback.
Testing	Vitest, PGlite	Clinical unit tests plus migrations and RLS against PostgreSQL-compatible execution.
Optional AI	Gemini, Groq or Anthropic	Short educational replies after deterministic safety checks.
Operations	PostHog, Sentry, Resend	Consent-gated analytics, error reporting and contact delivery when configured.

Why local-first

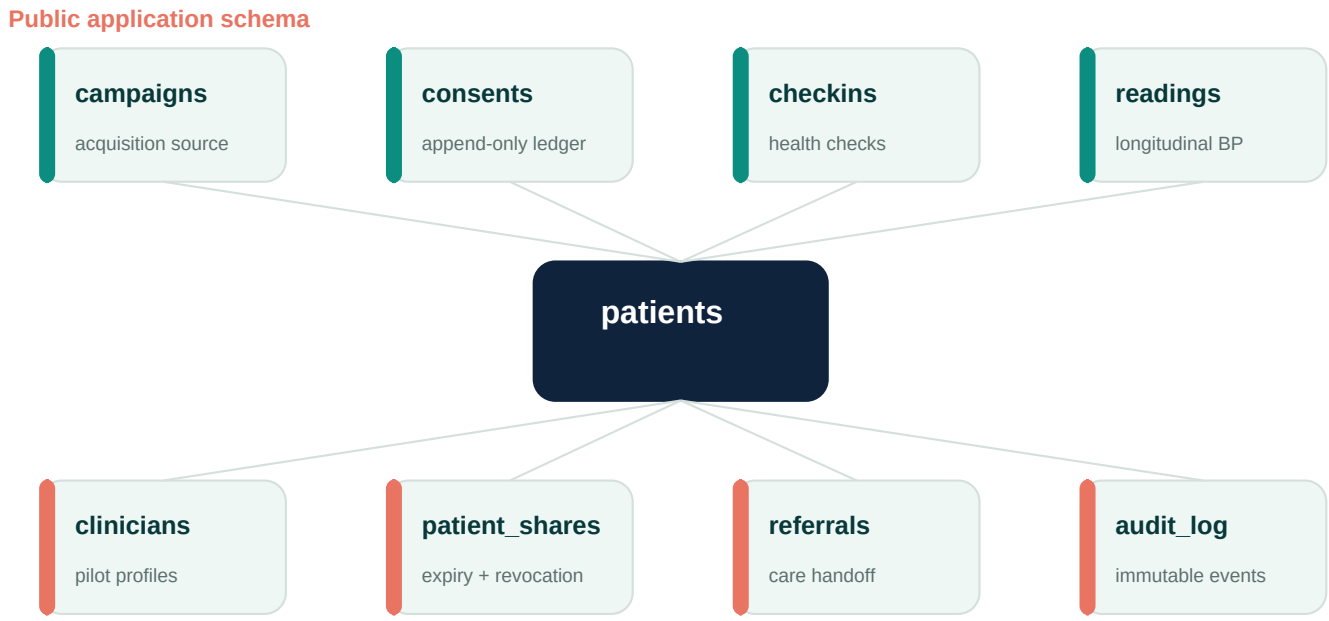
- A first health check does not depend on account creation or a working backend.

- Session storage keeps an unfinished check temporary; local storage keeps a saved Passport only after a user action.

- Stable event identifiers support idempotent sync after the user grants essential storage consent.

4. Data model and persistence

The schema separates screening events, longitudinal readings, consent and clinical sharing so each workflow remains auditable.



Schema inventory

- 10 public application tables: campaigns, patients, consents, checkins, readings, clinicians, patient_shares, referrals, audit_log and revoked_sessions.

- Research namespace: patient_surrogates plus consent-gated, generalized views for check-in facts and population summaries.

- Checkins store complete health-check events. Readings store standalone longitudinal BP measurements.

- Clinical category, urgency and mean arterial pressure are derived rather than accepted from clients.

Lifecycle

Stage	Storage	Control
In progress	sessionStorage	Clears with the browser session.
Saved offline	localStorage	Created only after an explicit user action.
Cloud record	Supabase PostgreSQL	Requires current essential consent and an authenticated identity.
Clinician access	patient_shares	Requires a live share, allowed clinician status, expiry and no revocation.
Research view	research schema	Requires research consent, generalization and k-anonymity of at least 5.

5. Security, privacy and consent

The database is the authorization boundary. Application checks add defense in depth but do not replace RLS.

Control	Implementation
Row isolation	RLS is enabled and forced. Patient and clinician policies scope records through auth.uid().
PII protection	Clinician names use AES-256-GCM in the application. Phone values use HMAC-SHA256 with a server-side pepper.
Session logout	Supabase global sign-out revokes refresh tokens. revoked_sessions rejects the active API token until expiry.
Patient sharing	The device creates the share secret. The database stores only its HMAC. Shares expire and can be revoked immediately.
Auditability	Consent and share events feed an append-only audit log. Client roles cannot rewrite history.
Consent	Essential, research and reminders are independent scopes in an append-only ledger. Missing consent evaluates to refusal.
Admin boundary	The admin console uses a separate server secret and service-role operations for clinician review.

Secrets

- SUPABASE_SERVICE_ROLE_KEY, PII_ENCRYPTION_KEY, PHONE_PEPPER, SHARE_TOKEN_PEPPER and ADMIN_TOKEN stay server-side.

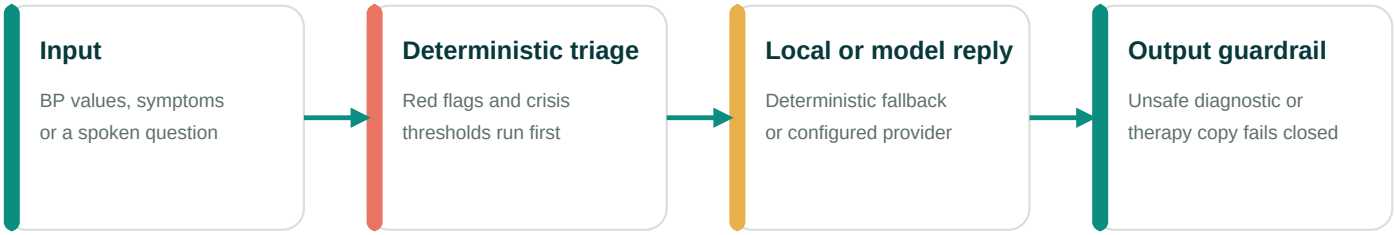
- Public variables contain only the Supabase URL, publishable key, canonical site URL, API origin and optional analytics key.

- The supplied Gemini key must be rotated because it appeared in chat. Store the replacement only in the production backend environment.

Pilot exception: pending clinician profiles may access only patient-authorized, expiring and read-only shares while PMDC integration is unavailable. Verified-only access remains a production launch requirement.

6. Clinical logic and assistant safety

Clinically consequential logic is isolated in pure TypeScript modules so it can be tested without the UI.



No provider key is required for the local coach. Voice transcription requires Gemini configuration.

Module	Responsibility
bp-classification.ts	ISH 2020 categories, independent urgency handling and rejection of implausible readings.
heart-score.ts	A 5-100 behavior score across modifiable factors plus the current reading. It is not presented as a validated cardiovascular risk score.
triage.ts	Keyword and threshold emergency detection across English, Urdu script and Roman Urdu. Runs before any model request.
drap-guardrail.ts	Blocks diagnostic or treatment wording. Unsafe output is discarded and replaced with a safe educational fallback.
presentation.ts	Converts clinical values into safe, localized explanations for UI presentation.

Assistant behavior

- Input is capped at 600 characters. Model output is short, low-temperature and passed through the guardrail.

- Voice recording accepts audio up to 5 MB. Gemini transcription returns text only; the normal assistant route handles the answer.

- The assistant describes readings and suggests a practical next step. It does not diagnose, prescribe or change a medicine dose.

7. API surface and core workflows

Sixteen route handlers cover health checks, accounts, assistant requests, consent, sharing, clinician access and programme review.

Group	Routes	Boundary
Platform	/api/health, /api/contact	Public health check and optional contact delivery.
Assistant	/api/v1/assistant, /api/v1/assistant/transcribe	Public request validation; model keys remain server-side.
Patient	/api/v1/passports, /api/v1/readings, /api/v1/consents, /api/v1/passport/history	Authenticated user plus database RLS.
Sharing	/api/v1/share, /api/v1/share/create, /api/v1/share/[token]	Authenticated patient; HMAC token storage and immediate revocation.
Account	/api/v1/auth/logout	Authenticated session plus service-role deny-list write.
Clinician	/api/v1/clinician/profile, /patients, /patients/[token]	Separate clinician profile and active patient authorization.
Admin	/api/v1/admin/clinicians	Server admin token and service-role access.

Main workflows

Workflow	Sequence
Email account	Register or sign in -> Supabase session -> patient profile -> consented sync.
Save reading	Validate -> authenticate -> check revocation -> RLS insert -> derived category and urgency.
Share record	Patient chooses clinician -> random secret -> HMAC stored -> expiring link -> clinician read-only view.
Logout	Write active session ID to revoked_sessions -> Supabase global sign-out -> reject token at API boundary.
Assistant	Validate -> deterministic triage -> configured model or local coach -> DRAP output guardrail.

8. Deployment and configuration

The app can run as one service or split web and API responsibilities while retaining a single repository.

Component	Recommended setup	Key configuration
Web	Vercel or combined Next.js host	NEXT_PUBLIC_SITE_URL, Supabase public values, optional NEXT_PUBLIC_API_URL.
API	Render or combined Next.js host	WEB_ORIGIN, service-role key, cryptographic keys, admin token and model keys.
Identity and DB	Supabase project in a low-latency region	Apply migrations 0001 through 0012. Enable Email and Anonymous Sign-Ins.
Monitoring	PostHog and Sentry when approved	Analytics loads only after consent. Health answers and BP readings stay out of analytics.
Contact	Resend with a verified sender domain	RESEND_API_KEY, CONTACT_EMAIL and CONTACT_FROM_EMAIL.

Production checklist

- Apply all migrations and verify RLS in the target Supabase project.
- Set the exact frontend origin in WEB_ORIGIN when the API is deployed separately.
- Add /en/account and /ur/account to Supabase redirect URLs.
- Generate stable random values for encryption, HMAC, sharing and admin secrets.
- Configure email authentication first. OAuth can remain disabled until redirect handling is intentionally introduced.
- Run npm run check and npm run build before deployment.
- Test register, sign in, sign out, consent, reading sync and clinician sharing against production-like infrastructure.

Environment groups

Public	Supabase URL and publishable key, API URL, site URL, consent version, optional PostHog values.
Server	Service-role key, WEB_ORIGIN, encryption key, phone pepper, share pepper, admin token.
Assistant	Gemini, Groq or Anthropic keys and model identifiers.
Operations	Sentry DSN and Resend contact values.

9. Quality status and next gates

The current repository is a functional pilot product. Several regulatory and operational gates remain before public clinical launch.

122	12	16	0
automated tests	database migrations	route handlers	production audit vulnerabilities

Release gates

Gate	Current position
Clinical validation	PHL sign-off on Heart Score weights remains required.
Regulatory	Written DRAP Class A confirmation remains required.
Security	Independent penetration testing remains required.
Clinician verification	Pilot access can include pending profiles. Verified-only access is required for regulated production.
Infrastructure	Production Supabase, hosting, email and monitoring values must be configured and tested.
Evidence	Pilot targets from the current plan: over 70% health-check completion, over 25% referral click-through and 40 of 50 clinicians rating the portal useful.

Roadmap

- Now: bilingual health check, Passport, email accounts, local-first storage, connected sync, clinician sharing, assistant, PWA and programme console.

- Next: production infrastructure, pilot validation, automated PMDC reconciliation and reviewed research export workflow.

- Later: Bluetooth cuff sync, laboratory integration, FHIR interoperability, corporate analytics and regional multi-tenant deployment.

Document basis

Current repository: README.md, package.json, .env.example, app/api, lib/clinical, lib/api, db/migrations and tests. Planning context: supplied investor, NIC, architecture, financial, go-to-market and risk documents. Epidemiological, financial and pilot-target figures should be revalidated before external publication.

BP Passport is an education and care-coordination product. It does not diagnose a person, prescribe treatment or replace a qualified clinician.